

Postal Address:
Box 8114
104 20 Stockholm
Website:
www.imy.se
Email:
imy@imy.se
Phone:
08-657 61 00
1(11)

Indecap AB

Decision after supervision according to the
Data Protection Regulation –
Indecap AB

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (Integritetsskyddsmyndigheten) finds that Indecap AB (556622–4480) has processed personal data in violation of Article 32.1 of the Data Protection Regulation by failing, in connection with an email dispatch on January 20, 2021, to ensure an appropriate level of security in relation to the risks of the processing.

The Swedish Authority for Privacy Protection decides, based on Articles 58.2 and 83 of the Data Protection Regulation, that Indecap AB shall pay an administrative fine of 500,000 SEK for the violation of Article 32.1 of the Data Protection Regulation.

Account of the supervisory case

The Swedish Authority for Privacy Protection (IMY) has received complaints alleging that Indecap AB (Indecap) incorrectly sent an email on January 20, 2021, containing a file with personal data about, among other things, customers' finances to other customers. IMY has initiated supervision against Indecap in order to investigate the matters raised in the complaints.

Indecap has stated that it considers itself the data controller for the relevant personal data processing. The company has also summarized the following.

All information in Indecap's system was protected and required user login to access the information included in the erroneous dispatch. What occurred in this case was that an employee retrieved information from the system containing personal data to process the information into a report in Excel. During the processing, the Excel file was saved and unfortunately named similarly to the general PDF report on the funds' performance that was to be sent to customers. When the employee later attempted to attach the PDF report to the dispatch, the employee accidentally attached the Excel file that was under processing and contained personal data, instead of the correct PDF report. Due to human error

1 Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation).

Reference Number:

DI-2021-3422

Date:

2023-11-07

Data Protection Authority

Case Number: DI-2021-3422

2(11)

Date: 2023-11-07

the mistake involved sending the incorrect file to a number of customers before the error was noticed and the dispatch was halted.

The incorrectly attached file that was sent via email to the company's customers contained information

about customers' names, personal identification numbers, bank, names of bank advisors, email addresses, selected risk levels, fund allocations (limited to individual fund choices), as well as the most recently recorded value of customers' holdings in these funds. The file did not contain any information about account numbers, login credentials, shareholdings in specific funds, or information about fund portfolios related to capital insurance, occupational or private pensions. The erroneous dispatches included personal data of 52,364 registered individuals and were received by a maximum of 2,813 persons. The exact number of recipients cannot be determined as Indecap's own investigations show that the email was caught in the mail filter of many customers.

Indecap has an information security policy and applies documented processes and procedures related to personal data and information security management. Before the incident occurred, Indecap had restricted access to the relevant systems concerning customer data, so that only four employees had access to these. Indecap had also trained all staff in personal data and information security management.

The internal investigation that Indecap conducted following the incident has revealed difficulties in adhering to Indecap's duality routine, which is applied during larger handling of personal data. The routine requires that two individuals approve/verify a certain action before it can be carried out. The reason for the difficulties in adhering to this routine is explained by the increased remote work necessitated by the Covid-19 pandemic. The step that was not carried out during the incident was to visually ensure, with a so-called four-eyes principle, that the correct data was entered into the system and attached correctly before the information was sent out via email. This could not be done remotely and allowed for the incorrect file to be attached. The file that was incorrectly included in the email was therefore not encrypted or contained any reading restrictions. Access to the originating computer was, however, both restricted based on authorization and password-protected.

Before the incident occurred, Indecap had launched a system-based application with login via BankID to reduce the risks that arise when information is sent via email. Indecap had decided prior to the incident to phase out its routine for email dispatches in 2021. Since the incident occurred, quarterly reports are no longer sent out via email. Customers are now referred to log in with BankID at Indecap to view their portfolio development. Furthermore, reports containing customer data are now encrypted and password-protected.

In addition to immediately halting all planned customer communication through letter/email dispatches, Indecap took a number of measures in connection with the incident. The company initiated a larger incident investigation together with external experts to map and document the event, as well as to perform a review of Indecap's systematic data protection efforts. The internal investigation, which has been completed, includes an analysis of the severity of the personal data incident according to ENISA's methodology for assessing personal data incidents and a plan for actions. Additionally, Indecap has updated procedures regarding remote work and the duality process, sent information to registrants about the incident, implemented further technical security measures, and conducted additional training sessions for employees.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-3422

3(11)

Date: 2023-11-07

Indecap has submitted a report of a personal data incident to IMY and made an incident report to the Financial Supervisory Authority regarding the event being investigated in this matter. In the report to IMY, Indecap stated, among other things, that the company had contacted the recipients who received the email containing personal data and requested that they delete the message and confirm that the message had been deleted.

Justification of the Decision

Applicable Provisions

The data controller is, according to Article 4.7 of the General Data Protection Regulation (GDPR), a natural or legal person, public authority, agency, or other body that alone or jointly with others determines the purposes and means of the processing of personal data. If the purposes and means of

processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how they are to be designated may be laid down in Union law or in the national law of the Member States. The data controller is responsible for and must be able to demonstrate compliance with the fundamental principles set out in Article 5 of the GDPR. This is stated in Article 5.2 of the GDPR.

According to Article 5.1 f of the GDPR, personal data must be processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures. Article 32.1 of the GDPR states that the data controller must implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing. In assessing what technical and organizational measures are appropriate, the data controller shall take into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of processing as well as the risks to the rights and freedoms of natural persons.

According to Article 32.1, appropriate protective measures, where appropriate, include:

- a) pseudonymization and encryption of personal data,
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services,
- c) the ability to restore the availability and access to personal data in a timely manner in the event of a physical or technical incident, and
- d) a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

According to Article 32.2 of the GDPR, in assessing the appropriate level of security, particular consideration shall be given to the risks posed by processing, in particular from accidental or unlawful destruction, loss, or alteration, or from unauthorized disclosure of, or unauthorized access to, personal data that has been transmitted, stored, or otherwise processed.

Member States may, according to Article 87 of the GDPR, specify the particular conditions under which a national identification number or any other commonly accepted means of identification may be processed. A national identification number or another commonly accepted means of identification shall in such cases only be used in compliance with...

Swedish Authority for Privacy Protection

Diary Number: DI-2021-3422

4(11)

Date: 2023-11-07

appropriate protective measures for the rights and freedoms of the data subjects under this regulation. According to Chapter 3, Section 10 of the Act (2018:218) on supplementary provisions to the EU General Data Protection Regulation, personal identification numbers and coordination numbers may be processed without consent only when it is clearly justified in relation to the purpose of the processing, the importance of secure identification, or some other significant reason.

Assessment by the Swedish Authority for Privacy Protection

Through the investigation of the case, it has been revealed that Indecap accidentally sent an unencrypted file containing personal data about approximately 52,000 customers via email to about 2,800 recipients who were not authorized to receive the relevant information. The file in question contained, among other things, information about customers' names, email addresses, personal identification numbers, banks, risk levels, individual fund choices, and the most recently recorded value of the customers' holdings in these funds.

Indecap is the Data Controller

Indecap has stated that the company is the data controller for the personal data processing being reviewed in this case.

The investigation shows that the purpose of sending the relevant message was to inform customers

about the general development of the funds. The Swedish Authority for Privacy Protection notes that Indecap has defined purposes and means for the processing of personal data, that is, how and why the personal data should be processed. Thus, it is Indecap that, according to Article 4.7 of the General Data Protection Regulation, has been the data controller for the relevant processing of personal data.

The Processing Involved a High Risk

According to Article 32 of the General Data Protection Regulation, Indecap has an obligation to protect the personal data that the company processes by taking appropriate technical and organizational measures. The measures must ensure an appropriate level of security. In assessing what level of security is appropriate, the data controller must consider the costs, the nature, scope, context, and purposes of the processing, and the risks to the rights and freedoms of natural persons posed by the processing.

According to Chapter 1, Section 11, first paragraph of the Act (2007:528) on the Securities Market, anyone who is or has been associated with a securities company must not improperly disclose or exploit what he or she has learned about someone else's business or personal circumstances during their employment or assignment. Since Indecap is a securities company, these legal requirements regarding confidentiality apply to the company's operations. This imposes high demands for the protection of the personal data processed in the business.

In this case, the data that has been handled has included particularly sensitive personal data, namely personal identification numbers, which may only be processed under certain conditions. There have also been economic data, such as the latest holdings in funds and the most recently recorded value of customers' holdings in these funds, for which the data subjects have legitimate expectations of a high degree of confidentiality and robust protection against unauthorized access. The Swedish Authority for Privacy Protection notes that the context of the personal data processing has resulted in an even higher requirement for the level of protection. The personal data processing has occurred within the framework of Indecap's core business, for which the company should have had a good ability to ensure a security level that was appropriate given the scope and sensitivity of the processing.

Integritetsskyddsmyndigheten

Darienummer: DI-2021-3422

5(11)

Datum: 2023-11-07

Compiling a large amount of personal data of a privacy-sensitive nature also entails specific risks, as the loss of control over such a compilation can lead to harm for many registered individuals. In the current case, the processing has involved data concerning a large number of registered individuals (approximately 52,000 persons).

Considering, among other things, that the data processed by Indecap has been of a protected nature and has concerned a very large number of individuals, Indecap's processing of personal data has overall posed a high risk to the rights and freedoms of natural persons. The nature, scope, and context of the processing have thus created a requirement for strong protection of the data. The measures should, among other things, ensure that personal data is protected against unauthorized disclosure and unauthorized access.

Indecap has not taken sufficient measures to protect the data

From the complaints and Indecap's account, it is evident that the file containing personal data was attached to an email that was sent out to a larger number of individuals. Indecap's distribution of the relevant file has meant that individuals who do not have the right to access the data have gained access to it.

Indecap has stated that the file was attached to the email due to a mistake by an individual employee. Indecap, as the data controller, is responsible for all personal data processing that occurs under the company's management or on behalf of the company. In this case, the incorrect attachment of the file occurred within the scope of the employee's duties. Indecap is responsible for ensuring that the processing of personal data carried out by the employee has been in accordance with the requirements of the data protection regulation regarding an appropriate level of security.

IMY further assesses that the current mistake could have been prevented or at least made more

difficult. Indecap processes both public and protected information in its operations. Depending on, among other things, the sensitivity of the information, different requirements are placed on the appropriate level of protection and thus the content of the routines for handling this data. In the handling of public information, for example, there is no reason to consider the risk of unauthorized access when choosing appropriate communication channels. To avoid compromising the protection of data of a protected nature, Indecap should have had clear routines to ensure that the handling of protected information would not be mixed up with the handling of public information. According to Indecap's own information, one reason for the incorrect file being attached was that it had been named similarly to another file that contained general information about the development of funds. This indicates that Indecap has not had sufficiently clear instructions to prevent documents containing customer data from being confused with other public documents.

It has also not been shown that Indecap implemented any technical or organizational barriers or control functions that would have complicated the incorrect handling of the file, e.g., technical barriers or warnings when attaching the file in an email. Indecap has indeed had a routine that requires each dispatch to be checked by staff in order to prevent this type of mistake. However, it has emerged that the relevant routine was not used due to difficulties in maintaining the routine while working from home during the then ongoing Covid-19 pandemic. IMY believes, however, that Indecap, in the situation that arose, particularly considering the sensitivity of the data the company processes in its core operations, should have taken other measures to ensure an adequate level of protection for the relevant data when the current protective measure could not be implemented due to the pandemic. The pandemic has thus not

Swedish Authority for Privacy Protection

Diary Number: DI-2021-3422

6(11)

Date: 2023-11-07

constituted a reasonable excuse to deviate from existing security procedures without replacing them with any other equivalent protection.

IMY notes that the lack of measures to prevent the transmission of sensitive personal data about customers has resulted in a high risk of employees making incorrect transmissions.

IMY further notes that the relevant file lacked protection in the form of, for example, access restrictions or encryption. After the file was incorrectly attached to the email, unauthorized individuals were thus able to access sensitive information about over 50,000 identifiable individuals in plain text. There was also a risk that the information could be further disseminated, for example, if one of the unauthorized recipients forwarded the email.

According to IMY, there have been deficiencies regarding the protection of personal data, both because Indecap did not take sufficient technical or organizational measures to prevent employees from incorrectly sending customer data via email to unauthorized recipients, and because the data was not protected against unauthorized access, e.g., through encryption.

Indecap's protective measures were supposed to ensure that personal data about the company's customers was protected against unauthorized disclosure and unauthorized access. However, through the email sent on January 20, 2021, to a large number of unauthorized recipients, Indecap disclosed unencrypted personal data about its customers, including information about the customers' finances. In summary, IMY concludes that Indecap has not taken sufficient technical and organizational measures to ensure a level of security that was appropriate in relation to the risk. Indecap has thus processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

Choice of Intervention

Legal Regulation

IMY has a number of corrective powers in the event of violations of the General Data Protection Regulation, including reprimands, orders, and administrative fines. This follows from Article 58.2 a–j of the General Data Protection Regulation. IMY shall impose administrative fines in addition to or instead of other corrective measures referred to in Article 58.2, depending on the circumstances of each individual case.

Each supervisory authority shall ensure that the imposition of administrative fines in each individual case is effective, proportionate, and dissuasive. This is stated in Article 83.1 of the General Data Protection Regulation. Article 83.2 specifies the factors to be considered in determining whether an administrative fine should be imposed and, if so, in what amount.

According to Article 83.4, in the event of violations of, among other things, Article 32, administrative fines of up to EUR 10,000,000 or, if it concerns a company, up to 2% of the total global annual turnover in the preceding financial year shall be imposed, depending on which value is higher.

Swedish Data Protection Authority

Diary Number: DI-2021-3422

7(11)

Date: 2023-11-07

The European Data Protection Board (EDPB) has adopted guidelines on the calculation of administrative fines under the General Data Protection Regulation aimed at creating a harmonized method and principles for calculating fines.

If it concerns a minor infringement, IMY may, as stated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b of the Regulation.

IMY's Assessment

A fine shall be imposed

IMY has assessed that Indecap has processed personal data in violation of Article 32.1 of the General Data Protection Regulation.

The infringement occurred because Indecap processed personal data with an insufficient level of security, which resulted in, among other things, financial data about over 50,000 data subjects being sent via email to approximately 2,800 unauthorized recipients. Indecap was aware of the risks associated with email dispatches and had therefore implemented specific control procedures, but due to the pandemic, deviated from the control procedure without taking compensatory protective measures. The erroneous dispatch has resulted in a high risk to the rights and freedoms of the data subjects, including the loss of confidentiality for sensitive data.

In light of this, IMY assesses that it is not a minor infringement. Therefore, Indecap shall be imposed an administrative fine for the infringement. In determining the amount of the fine, IMY shall consider the circumstances specified in Article 83.2 and ensure that the administrative fine is effective, proportionate, and dissuasive.

The parent company's annual turnover shall be the basis for the calculation

In determining the maximum amount of the fine, the definition of the concept of an undertaking as derived from the case law of the Court of Justice of the European Union according to Articles 101 and 102 of the Treaty on the Functioning of the European Union shall be used (see Recital 150 of the General Data Protection Regulation). The case law indicates that the concept of an undertaking encompasses any entity engaged in economic activity, regardless of the legal form of the entity and the manner of its financing, and even if the entity legally consists of several natural or legal persons.

What constitutes an undertaking shall thus be based on the definitions from competition law. The rules for group liability in EU competition law revolve around the concept of an economic unit. A parent company and a subsidiary are considered part of the same economic unit when the parent company exerts decisive influence over the subsidiary. The decisive influence (i.e., control) can be achieved either through ownership or through agreements. The case law of the Court of Justice indicates that 100 percent or nearly 100 percent ownership creates a presumption that control is deemed to exist. However, this presumption can be rebutted if the company provides sufficient evidence to demonstrate that the subsidiary operates independently in the market. To rebut the presumption, the company must therefore provide evidence concerning the organizational, economic, and legal connections between the subsidiary and its parent company that shows they do not constitute an economic unit despite the parent company holding 100 percent or nearly 100 percent of the shares.

2 EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, adopted on

May 24, 2023.

3 Case C-97/08, paragraphs 59-61

4 Cf. EDPB Guidelines 04/2022 on the calculation of administrative fines under the GDPR, paragraph 125 and the decisions cited therein.

Swedish Authority for Privacy Protection

Diary Number: DI-2021-3422

8(11)

Date: 2023-11-07

The group in which Indecap is included consists of three companies: the parent company Indecap Holding AB and the two sister companies Indecap and Indecap Fonder AB. The commission income of Indecap Holding AB consists of the commission income from Indecap and Indecap Fonder AB.

Indecap has argued that the revenue attributable to Indecap Fonder AB should be excluded when calculating an administrative fine. In support of this, Indecap has stated that the current violation occurred only in one of the group companies, namely Indecap. Indecap is a securities company that provides individual pension savings and advice in the fund market. Indecap Fonder AB, in turn, is a fund company that manages nine funds within various equity and bond strategies. Indecap Fonder AB has few direct customers and distributes the funds through various platforms and banks. Although Indecap Fonder AB's funds are selectable at Indecap, Indecap's fund portfolios also consist of many other funds that have no connection to either Indecap Fonder AB or Indecap Holding AB. The customer data included in the mailing belonged only to customers of Indecap.

Indecap Holding AB owns 100 percent of the shares in Indecap, and there is therefore a presumption that Indecap and Indecap Holding AB are an economic unit. Indecap has not presented anything that shows that Indecap acts independently in relation to the parent company, which would break the presumption. The fact that subsidiaries in the group have operations with different focuses, or that an incident has only occurred in one subsidiary, are not circumstances that in themselves affect the presumption of the parent company's influence.

IMY assesses, considering the above, that the company's revenue that should be the basis for calculating the administrative fine that Indecap may be imposed is Indecap's parent company Indecap Holding AB (556971-6987).

In the EDPB's guidelines, the starting point is that annual revenue refers to the company's net revenue, i.e., the amount received from the sale of goods and provision of services after deducting sales discounts and value-added tax as well as other taxes directly related to the revenue. To determine what revenue Indecap Holding AB had during the previous financial year, IMY has obtained information from the group's annual report for 2022. This information shows that Indecap Holding AB had commission income amounting to 558,260,000 SEK.

Indecap has stated that Indecap Holding AB's annual report is prepared in accordance with the Act (1995:1559) on annual reports in credit institutions and securities companies and that the item for commission income does not accurately reflect the group's net revenue. The relevant commission income is stated before the Pensionsmyndigheten's agreed mandatory discount on management fees has been deducted. The agreement with Pensionsmyndigheten regarding the discount is a requirement for a fund company to be able to offer funds on the premium pension fund market. Discounts to Pensionsmyndigheten amounted to 394,326,770 SEK in 2022. Thus, Indecap Holding AB's net revenue is the sum

5 EDPB's guidelines Guidelines 04/2022 on the calculation of administrative fines under the GDPR, points 128-130.

6 The definition corresponds to that stated in Article 5.2 of the European Parliament and Council Directive 2013/34/EU of June 26, 2013, on annual financial statements, consolidated financial statements, and reports in certain types of companies, amending European Parliament and Council Directive 2006/43/EC and repealing Council Directives 78/660/EEC and 83/349/EEC Text of relevance to the EEA and implemented in Swedish law through Chapter 1, Section 3, third paragraph of the Annual Accounts Act (1995:1554).

that remains after this discount has been deducted. Indecap has submitted documents to support the discounts provided to the Swedish Pensions Agency.

IMY makes the following assessment. Indecap Holding AB's annual report does not contain a clear accounting entry that can be equated with the company's net turnover. For a sanction fee to have the corresponding effect regardless of which accounting rules the intervention is directed against, it is, according to IMY, essential that the turnover is calculated in such a way that it corresponds to what would have constituted net turnover if the accounting rules of the Annual Accounts Act had been applied. There are no guiding clarifications from the Court of Justice of the European Union or the EDPB that clarify how annual turnover in credit institutions and securities companies should be calculated. Therefore, IMY assesses, in light of the fact that net turnover should be determined after deducting granted discounts, that the relevant annual turnover for Indecap Holding AB should be assessed after deducting discounts on management fees. Indecap has substantiated through submitted documents that the discounts to the Swedish Pensions Agency during the year 2022 amounted to the amount they specified.

IMY assesses, considering the above, that the relevant annual turnover for Indecap Holding AB is approximately 140,199,260 SEK. Two percent of that annual turnover is approximately 2,800,000 SEK. The highest sanction amount that can be determined in this case is therefore 10,000,000 EUR.

Severity of the Violation

IMY assesses that the following factors are significant for the assessment of the severity of the violation.

IMY has established that Indecap did not take sufficient technical and organizational measures to reduce the risk of personal data about the company's customers being disclosed to unauthorized parties. The relevant security deficiencies have led to an incident that has affected a large number of registered individuals, and a significant number of unauthorized recipients have been able to access others' personal data in clear text. The data has included financial information and personal identification numbers, i.e., information that requires strong protection. The handling of personal data was also part of Indecap's core business, where the data was subject to statutory confidentiality. Indecap was also aware of the risks associated with email dispatches and had therefore implemented specific control routines, but due to the pandemic, deviated from the control routine without taking compensatory protective measures.

In assessing the severity of the violation, IMY considers, as a mitigating factor, that Indecap had already begun work to replace email dispatches with a more secure alternative before the incident in question. This process was also expedited after the incident.

According to the EDPB's guidelines, the supervisory authority should assess whether the violation is of low, medium, or high severity. IMY assesses, in light of the above circumstances, that it collectively constitutes a violation of Article 32.1 of the Data Protection Regulation of medium severity.

As a mitigating circumstance, it is noted that Indecap, before IMY initiated supervision, promptly and clearly informed the affected data subjects about what had occurred. IMY also considers that Indecap contacted the recipients of the erroneously sent email and asked them to delete the message and confirm that this had been done, as a mitigating circumstance.

The Sanction Fee Must Be Effective, Proportional, and Deterrent

The administrative sanction fee must be effective, proportional, and deterrent. This means that the amount should be determined so that the administrative sanction fee leads to rectification, provides a preventive effect, and is also proportional in relation to both the violations in question and the supervisory subject's ability to pay.

IMY assesses that a sanction fee calculated on the parent company's total net turnover would, in this particular case, not lead to the sanction fee being set too high in relation to the violation established in the case. There is therefore no reason to reduce the sanction fee on the grounds that the violation only

concerned one company in the group.

In light of the severity of the violation, aggravating and mitigating circumstances, IMY determines the administrative sanction fee for Indecap to be 500,000 SEK for the established violation. IMY assesses that this amount is effective, proportional, and deterrent.

This decision has been made by the unit manager Catharina Fernquist after presentation by the lawyer Evelin Palmér. In the final handling, the legal manager David Törngren, lawyer Cecilia Agnehall, and IT and information security specialist Katarina Bengtsson have also participated.

Catharina Fernquist, 2023-11-07 (This is an electronic signature)

Copy to:

1. The Complainants

Swedish Authority for Privacy Protection

Case Number: DI-2021-3422

Page 11 of 11

Date: 2023-11-07

How to Appeal

If you wish to appeal the decision, you should write to the Swedish Authority for Privacy Protection. Indicate in the letter which decision you are appealing and the change you are requesting. The appeal must be received by IMY no later than three weeks from the day you received the decision. If the appeal is submitted in a timely manner, IMY will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to IMY if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.